‘DarkSword’ iOS Exploit Kit Used by State-Sponsored Hackers, Spyware Vendors

securityweek.com/darksword-ios-exploit-kit-used-by-state-sponsored-hackers-spyware-vendors

Ionut Arghire March 18, 2026

Security researchers have discovered another sophisticated iOS exploit kit and found evidence that it has been used by both state-sponsored hackers and commercial spyware vendors.

A Russian state-sponsored espionage group tracked as UNC6353 has been using the iOS exploit kit in attacks against Ukraine.

In early March, Google and iVerify shared details on Coruna, a powerful exploit kit targeting 23 vulnerabilities in iOS 13 through 17.2.1, including nearly a dozen zero-days.

Flagged as the first mass-exploitation kit targeting iOS devices, Coruna was used by UNC6353 in watering hole attacks against Ukraine and later leveraged by financially motivated groups due to its cryptocurrency-theft capabilities.

On Wednesday, iVerify, Google, and Lookout shared details on a second mass-exploitation iOS kit used by UNC6353. Named DarkSword, it targets six vulnerabilities in Apple’s mobile platform and leads to full device compromise with minimal user interaction.

DarkSword shares infrastructure with Coruna and was used in watering hole attacks against Ukraine, suggesting that they are part of the same threat actor’s arsenal.

Google has also found evidence that DarkSword has been used by commercial surveillance vendors, including one tracked as UNC6748, in attacks targeting Saudi Arabia, Turkey, and Malaysia.

Written completely in JavaScript, DarkSword starts with the exploitation of Safari bugs to achieve remote code execution (RCE), continues with a sandbox escape, and shifts to exploiting kernel flaws to inject and execute JavaScript code for privilege escalation and final payload execution.

The observed attacks were mounted through malicious iframes injected in the websites of the independent news agency News of Donbas and the official website for the Seventh Administrative Court of Appeals in Vinnytsia.

The full exploit chain

The targeted vulnerabilities include CVE-2025-31277, CVE-2025-43529, CVE-2025-14174, CVE-2025-43510, CVE-2025-43520, and CVE-2026-20700.

CVE-2025-31277 and CVE-2025-43529 are two WebContent process JIT issues leading to arbitrary memory read/write primitives that DarkSword exploits during the initial phase of the attack.

It then proceeds to target CVE-2026-20700 for Trusted Path Read-Only (TPRO) and Pointer Authentication Codes (PAC) protections bypass and arbitrary code execution. The flaw was patched in February as a zero-day.

Next, the exploit chain targets CVE-2025-14174, an out-of-bounds write vulnerability in ANGLE, combined with the PAC bypass, to escape Safari's sandbox via the GPU process. CVE-2025-43529 and CVE-2025-14174 were patched in December.

From the GPU process, the exploit targets the XNU kernel via CVE-2025-43510, a copy-on-write bug that provides arbitrary memory read/write primitives in the mediaplaybackd daemon, which are then leveraged to exploit CVE-2025-43520 for kernel privilege escalation.

Extensive information theft capabilities

The final payload, Lookout explains, is an orchestrator for numerous modules that enable the attackers to exfiltrate sensitive information from the infected devices.

It targets passwords, photos, WhatsApp and Telegram messages, text messages, contacts, call history, browser data (cookies, history, and passwords), installed applications, Wi-Fi data and passwords, Apple Health data, calendar and notes, information on the connected accounts, and cryptocurrency wallets.

"This malware is highly sophisticated and appears to be a professionally designed platform enabling rapid development of modules through access to a high-level programming language. This extra step shows a significant effort put into the development of this malware with

thoughts about maintainability, long-term development, and extensibility," Lookout notes.

The cybersecurity firm also notes that DarkSword's crypto-targeting capabilities suggest that UNC6353 might have expanded its capabilities into financial theft, or that it was a financially motivated threat actor all along. The Coruna exploit used by UNC6353 did not target cryptocurrency wallets.

Millions of iPhones potentially impacted

Apple has rolled out patches for all the vulnerabilities targeted by both Coruna and DarkSword, but hundreds of millions of devices may still be exposed to attacks, the security researchers warn.

"We estimate that the DarkSword exploit chain still impacts a significant portion of iPhone users. Specifically, 14.2% of users (approximately 221,520,000 devices) running iOS versions between 18.4 and 18.6.2 are believed to be vulnerable," iVerify says.

The cybersecurity firm notes that the number of affected devices might be much higher if the targeted vulnerabilities can be exploited against iOS versions below 18.4 and above 26.x.

"Based on the assumption that all iOS 18 versions are susceptible to the majority of the vulnerabilities in this chain, approximately 18.99% of users (296,244,000) may be affected," iVerify explains.

Users are advised to update to iOS versions 26.3.1 and 18.7.6, which are the latest platform iterations to include patches for all vulnerabilities in the DarkSword exploit kit.

Attacks in Saudi Arabia, Turkey, and Malaysia

Over the past five months, Google identified three payloads dropped in successful DarkSword attacks, namely GhostBlade, GhostKnife, and GhostSaber.

In November 2025, the internet giant says, DarkSword was used by UNC6748 to target Saudi Arabian users in a watering hole attack employing a Snapchat-themed website. The malware used, Ghostknife, is a JavaScript backdoor that packs extensive information theft capabilities.

In late November, commercial surveillance vendor PARS Defense employed DarkSword in attacks against users in Turkey, and in January 2025 used it in attacks against Malaysian users.

The payload in these attacks was GhostSaber, a JavaScript backdoor capable of file exfiltration, device and account enumeration, data theft, and arbitrary JavaScript code execution.

The UNC6353 attacks employing DarkSword against Ukraine started in December 2025, delivering the GhostBlade malware, which packs information-stealer functionality but lacks backdoor capabilities, in line with iVerify's and Lookout's findings.

“There are notable similarities and differences between the exploit delivery implementations used by UNC6748, PARS Defense, and UNC6353. We assess that each of the actors built their delivery mechanisms on a base set of logic from the DarkSword developers, and made tweaks to fit their own needs,” Google explains.

Google also notes that, while the DarkSword exploit used by UNC6353 only targeted devices running iOS versions 18.4-18.6, the variant employed by UNC6748 and PARS Defense also targeted iOS version 18.7.

“Watering-hole attacks abusing compromised legitimate websites are essentially zero-click attacks in that the intended victim might already be frequenting the malicious site anyway. Even if a user needs to be lured to the site, social engineering defensive training is not effective since the infection URL is legitimate,” Lookout notes.

**Updated with additional information from Google.*

Related: Apple Updates Legacy iOS Versions to Patch Coruna Exploits

Related: CISA Adds iOS Flaws From Coruna Exploit Kit to KEV List

Related: US Sanctions Russian Exploit Broker Operation Zero

Related: Russia’s APT28 Rapidly Weaponizes Newly Patched Office Vulnerability

- Critical Langflow Vulnerability Exploited Hours After Public Disclosure
- Oasis Security Raises $120 Million for Agentic Access Management
- 1stProtect Emerges From Stealth With $20 Million in Funding
- Critical ScreenConnect Vulnerability Exposes Machine Keys
- Security Firm Aura Discloses Data Breach Impacting 900,000 Records
- Russian APT Exploits Zimbra Vulnerability Against Ukraine
- Raven Emerges From Stealth With $20 Million in Funding
- EU Sanctions Chinese, Iranian Firms Supporting Hacking Operations

Latest News

- In Other News: New Android Safeguards, Operation Alice, UK Toughens Cyber Reporting

- 3 Men Charged With Conspiring to Smuggle US Artificial Intelligence to China
- Eclypsium Raises $25 Million for Device Supply Chain Security
- US Confirms Handala Link to Iran Government Amid Takedown of Hackers' Sites
- Cape Raises $100 Million for Protection Against Cellular Security Threats
- Navia Data Breach Impacts 2.7 Million
- Thousands of Magento Sites Hit in Ongoing Defacement Campaign
- Allure Security Raises $17 Million for Online Brand Protection